

MAPEO NORMATIVO DE PREGUNTAS

Correspondencia de cada pregunta de la encuesta con los requisitos normativos aplicables

Kit de Encuesta FISMA 2025 — Documento de referencia técnico-normativo

"Cada pregunta de esta encuesta tiene un padre normativo y, en muchos casos, más de uno. Lo que sigue es la genealogía completa."

Tabla 1 — Mapeo Completo: Pregunta ↔ Norma ↔ Dominio FISMA ↔ Función CSF 2.0

Nº Pregunta	Tema de la pregunta	Dominio FISMA FY2025	Función CSF 2.0	Artículo ENS (RD 311/2022)	Artículo / Área NIS2	Indicador FISMA FY2025	Referencia NIST SP
P1	Política de Seguridad aprobada por órgano directivo	Cybersecurity Governanc e	GOVERN	Art. 13 (Política de Seguridad)	Art. 21.1 (Políticas de seguridad)	Métrica Gov-1	NIST CSF 2.0: GV.OC, GV.RR
P2	Participación órgano directivo en decisiones de ciberseguridad	Cybersecurity Governanc e	GOVERN	Art. 13.2 (Responsabilidades)	Art. 20 (Responsabilidad de órganos de dirección)	Métrica Gov-2	NIST SP 800-53 Rev.5: PM-1, PM-2
P3	Estrategia de gestión del riesgo cibernético	Cybersecurity Governanc e	GOVERN	Art. 14 (Gestión de riesgos)	Art. 21.2.a (Análisis de riesgos)	Métrica Gov-3 (Suplementaria)	NIST SP 800-53: RA-2, PM-9
P4	Uso de Perfiles CSF / marcos de referencia	Cybersecurity Governanc e	GOVERN	Art. 5 (Principio de GBR)	Art. 21.1 (medidas proporcionales al riesgo)	Métrica Gov-1 (Suplementaria)	NIST CSF 2.0: GV.RM
P5	KPIs de ciberseguridad y rendición de cuentas	Cybersecurity Governanc e	GOVERN	Art. 13 + Art. 34 (Auditoría)	Art. 20.2 (responsabilidad personal directivos)	Métrica Gov-2	NIST SP 800-53: PM-6
P6	Inventario de proveedores con acceso a sistemas	C-SCRM	GOVERN	Art. 19 (Adquisición de productos /servicios)	Art. 21.2.d (Seguridad cadena de suministro)	Métrica SCRM-1	NIST SP 800-161r1: SR-1, SR-2

P7	Cláusulas de ciberseguridad en contratos TIC	C-SCRM	GOVERN	Art. 19.3 (Condiciones contractuales)	Art. 21.2.d (Acuerdos con proveedores)	Métrica SCRM-2	NIST SP 800-161r1: SR-5, SR-10
P8	Evaluación de ciberseguridad de proveedores	C-SCRM	GOVERN	Art. 19 + CCCN-STIC 830	Art. 21.2.d (Evaluación de proveedores)	Métrica SCRM-3	NIST SP 800-161r1: SA-4, SR-3
P9	Seguimiento continuo del estado de proveedores	C-SCRM	GOVERN	Art. 19 (Vigilancia del servicio)	Art. 21.2.d (Supervisión continua)	Métrica SCRM-2	NIST SP 800-161r1: SR-6
P10	Plan de contingencia ante fallos de proveedores	C-SCRM / Contingency Planning	GOVERN / RECOVER	Art. 19 + Art. 26 (Continuidad)	Art. 21.2.c (Continuidad operativa)	Métrica SCRM-3 / CP-1	NIST SP 800-34: CP-2, CP-7
P11	Inventario completo de activos de información	Risk and Asset Management	IDENTIFY	Medida op.exp.1 (Inventario de activos)	Art. 21.2.a (Gestión de activos)	Métrica RA-1	NIST SP 800-53: CM-8, PM-5
P12	Categorización de sistemas por nivel de criticidad	Risk and Asset Management	IDENTIFY	Art. 40-44 (Categorización)	Art. 21.1 (Proporcionalidad al riesgo)	Métrica RA-2	NIST FIPS 199; NIST SP 800-60
P13	Análisis de riesgos formales	Risk and Asset Management	IDENTIFY	Art. 14 (Gestión de riesgos)	Art. 21.2.a (Análisis de riesgos y seguridad)	Métrica RA-3	NIST SP 800-30; NIST SP 800-39

P14	Gestión de activos IoT / OT	Risk and Asset Management	IDENTIFY	Medida op.exp.1 (todos los activos)	Art. 21.2.g (IoT/OT en entidades esenciales)	Métrica RA-1 (extensión OT)	NIST SP 800-82 (ICS); CDM IoT metrics
P15	Líneas base de configuración segura (hardening)	Configuration Management	PROTECT	Medida mp.eq.3 (Seguridad en equipos)	Art. 21.2.b (Controles de red y seguridad)	Métrica CM-1	NIST SP 800-70; CIS Benchmarks
P16	Tiempo medio de aplicación de parches críticos	Configuration Management	PROTECT	Medida op.exp.4 (Gestión de parches)	Art. 21.2.e (Mantenimiento actualizado)	Métrica CM-2	NIST SP 800-40 Rev.4; CISA KEV
P17	Sistema de gestión automatizada de vulnerabilidades	Configuration Management	PROTECT / DETECT	Medida op.exp.3 (Protección frente a código malicioso)	Art. 21.2.b (Evaluación de vulnerabilidades)	Métrica CM-3 / ISCM-2	NIST SP 800-53: RA-5, SI-2
P18	Proceso formal de gestión de cambios	Configuration Management	PROTECT	Medida op.exp.5 (Gestión de cambios)	Art. 21.2.f (Gestión de incidentes y cambios)	Métrica CM-1	NIST SP 800-53: CM-3, CM-4
P19	Implementación de MFA	Identity and Access Management	PROTECT	Medida mp.acc.5 (Autenticación fuerte)	Art. 21.2.i (Autenticación multifactor)	Métrica IDAM-1	NIST SP 800-63B (AAL2/AAL3)
P20	Revisión periódica de permisos y accesos	Identity and Access Management	PROTECT	Medida mp.acc.4 (Proceso de control de acceso)	Art. 21.2.i (Gestión de accesos)	Métrica IDAM-2	NIST SP 800-53: AC-2, AC-6
P21	Principio de mínimo privilegio	Identity and Access Management	PROTECT	Medida mp.acc.2 (Acceso mínimo necesario)	Art. 21.2.i (Principio mínimo privilegio)	Métrica IDAM-2	NIST SP 800-53: AC-6; ZTA Pilar Identidad

P22	Gestión de accesos privilegiados (PAM)	Identity and Access Management	PROTECT	Medida mp.acc.3 (Control de acceso privilegiado)	Art. 21.2.i (Accesos privilegiados)	Métrica IDAM-3	NIST SP 800-53: AC-17, IA-5
P23	Arquitectura Zero Trust (ZTA)	Zero Trust / IDAM / ISCM	PROTECT / DETECT	Sin mención explícita ENS (principio defensa en profundidad)	Sin mención directa NIS2	Métricas ZTA-1, ZTA-2 (Suplementarias FY2025)	NIST SP 800-207; CISA ZTMM v2.0
P24	Inventario / mapa de datos	Data Protection and Privacy	PROTECT	Medida mp.info.3 (Clasificación de la información)	Art. 21.2.a (Gestión de datos y privacidad)	Métrica DP-1	NIST SP 800-53: RA-2, MP-1
P25	Cifrado de datos en reposo y tránsito	Data Protection and Privacy	PROTECT	Medida mp.info.3 + mp.com.2 (Cifrado de datos)	Art. 21.2.h (Cifrado)	Métrica DP-2	NIST SP 800-175B; FIPS 140-3
P26	Evaluaciones de impacto en privacidad (DPIA)	Data Protection and Privacy	PROTECT	Art. 11 (Proporcionalidad) + LOPDGDD	Art. 21 (coherente con RGPD)	Métrica DP-3	NIST SP 800-53: PT-2; ISO/IEC 29134
P27	Preparación para criptografía post-cuántica (PQC)	Data Protection and Privacy (emergente)	PROTECT	Sin mención explícita ENS (Art. 14 gestión riesgos emergentes)	Sin mención NIS2 (riesgo emergente)	Futura métrica PQC (FY2026-27 estimado)	NIST FIPS 203/204/205 (agosto 2024)

P28	Programa formal de formación y concienciación	Security Training	PROTECT	Art. 15 (Profesionalidad) + Art. 16 (Formación)	Art. 20.2 (formación directivos) + Art. 21.2.j (concienciación)	Métrica ST-1	NIST SP 800-50; NIST NICE Framework
P29	Simulacros de phishing	Security Training	PROTECT	Art. 16 (Formación en ciberseguridad)	Art. 21.2.j (Formación práctica)	Métrica ST-2	NIST SP 800-50; NIST SP 800-177
P30	Formación específica para directivos	Security Training / Governance	PROTECT / GOVERN	Art. 16 + Art. 13 (responsabilidades directivas)	Art. 20.1 (formación obligatoria directivos NIS2)	Métrica ST-1 / Gov-2	NIST CSF 2.0: GV.OC; NIST SP 800-50
P31	SIEM o sistema de correlación de eventos	Information Security Continuous Monitoring	DETECT	Art. 24 (Vigilancia continua)	Art. 21.2.b (Detección de incidentes)	Métrica ISCM-1	NIST SP 800-137; OMB M-21-31
P32	EDR / XDR en endpoints	Information Security Continuous Monitoring	DETECT	Medida mp.eq.3 + op.exp.3 (Protección endpoints)	Art. 21.2.b (Seguridad de endpoints)	Métrica ISCM-2	NIST SP 800-53: SI-3, SI-4
P33	Cobertura de logs de eventos	Information Security Continuous Monitoring	DETECT	Art. 24 + medida op.exp.10 (Registro de actividad)	Art. 21.2.b (Logging y monitorización)	Métrica ISCM-3 (alineada con OMB M-21-31 EL1-EL3)	NIST SP 800-92; OMB M-21-31

P34	Programa CDM o equivalente	Information Security Continuous Monitoring	DETECT	Art. 24 (Vigilancia continua)	Sin equivalente directo NIS2	Métrica ISCM-1 (CDM reporting $\geq 90\%$ GFE)	CISA CDM Program; NIST SP 800-137
P35	Threat hunting proactivo	Information Security Continuous Monitoring	DETECT	Art. 24 (Vigilancia continua proactiva)	Art. 21.2.b (Detección avanzada de amenazas)	Métrica ISCM-4	NIST SP 800-53: SI-4; MITRE ATT&CK
P36	Plan de Respuesta a Incidentes (IRP)	Incident Response	RESPOND	Art. 25 (Respuesta a incidentes)	Art. 21.2.f (Gestión de incidentes)	Métrica IR-1	NIST SP 800-61r3
P37	Ejercicios de respuesta a incidentes	Incident Response	RESPOND	Art. 25 (Planes de prueba)	Art. 21.2.f (Prueba de planes)	Métrica IR-2	NIST SP 800-84; NIST SP 800-53: IR-3
P38	SLAs de respuesta a incidentes	Incident Response	RESPOND	Art. 25 (Objetivos de respuesta)	Art. 21.2.f (Eficiencia en respuesta)	Métrica IR-3	NIST SP 800-61r3: sección 3.4
P39	Notificación de incidentes a autoridades	Incident Response	RESPOND	Art. 25.2 + CCN-STIC 817 (ITS Notificación)	Art. 23 (Notificación obligatoria: $<24h / <72h$)	Métrica IR-1 (reporte incidentes mayores OMB)	NIST SP 800-61r3; CISA 52.204-21
P40	CSIRT/ CERT interno o MSSP con IR	Incident Response	RESPOND	Art. 25 (Capacidad de respuesta)	Art. 21.2.f (Capacidades de IR)	Métrica IR-1	NIST SP 800-53: IR-7, IR-8
P41	BCP / DRP documentados	Contingency Planning	RECOVER	Art. 26 (Continuidad de actividad)	Art. 21.2.c (Continuidad operativa)	Métrica CP-1	NIST SP 800-34 Rev.1; ISO 22301

P42	Pruebas de continuidad y recuperación	Contingency Planning	RECOVER	Art. 26 (Prueba de planes de continuidad)	Art. 21.2.c (Pruebas de continuidad)	Métrica CP-2	NIST SP 800-34; NIST SP 800-53: CP-4
P43	RTO y RPO definidos y probados	Contingency Planning	RECOVER	Art. 26 (Objetivos de recuperación)	Art. 21.2.c (RTO/RPO en continuidad operativa)	Métrica CP-1	NIST SP 800-34: sección 3.1
P44	Estrategia de backup 3-2-1	Contingency Planning	RECOVER	Art. 26 + medida mp.info.9 (Copias de seguridad)	Art. 21.2.c (Copias de seguridad)	Métrica CP-2	NIST SP 800-53: CP-9, CP-10
P45	Certificación ENS	Cumplimiento normativo	Transversal	Art. 37-40 RD 311/2022 (Certificación)	Reconocimiento ENS equiv. (Art. 24.2 NIS2)	N/A (métrica de cumplimiento nacional)	N/A
P46	Ámbito NIS2 y dificultades de implementación	Cumplimiento normativo	Transversal	Art. 2 RD 311/2022 (Ámbito)	Arts. 20-23 NIS2 (Obligaciones entidades)	N/A (métrica de cumplimiento EU)	N/A
P47	Frecuencia de auditorías independientes	Cumplimiento normativo / Governance	GOVERN	Art. 34-36 RD 311/2022 (Auditoría bienal)	Art. 21.1 (Revisión y auditoría)	N/A (auditoría IG FISMA equivalente)	NIST SP 800-53: CA-2, CA-7
P48	Plan de Acción y Mejora (PAM/POA&M)	Cumplimiento normativo / Governance	GOVERN	Art. 36 (Resolución de deficiencias)	Art. 21 (Mejora continua)	POA&M management (FISMA core process)	NIST SP 800-53: CA-5; OMB FISMA guidance
P49	KPIs / KRIs de ciberseguridad	Métricas y madurez	Transversal	Art. 34 (Métricas de gestión)	Art. 21.1 (Proporcionalidad medible)	Todas las métricas FISMA FY2025	NIST CSF 2.0: GV.RM; NIST SP 800-55

P50	Nivel de madurez autoevaluado (1-5)	Métricas y madurez	Transversal	INES (herramienta de autoevaluación CCN)	N/A (instrumento propio NIS2)	Modelo de madurez FISMA 5 niveles	NIST SP 800-53; CMMI for Security
P51	Presupuesto de ciberseguridad (% sobre TI)	Métricas y madurez	Transversal	Art. 14 (Recursos adecuados)	Art. 21.1 (Medidas adecuadas y proporcionadas)	Métrica financiera complementaria	ENISA NIS Investments 2025 benchmark
P52	Incidentes sufridos en últimos 12 meses	Métricas y madurez / Incident Response	RESPOND	Art. 25 + INES (métricas de incidentes)	Art. 23 (Registro de incidentes)	Métrica IR-1 (major incidents)	NIST SP 800-61r3
P53	Uso de inteligencia de amenazas (CTI)	Tendencias emergentes / ISCM	DETECT / IDENTIFY	Art. 24 (Vigilancia continua)	Art. 26.3 NIS2 (cooperación e intercambio de información)	Métrica ISCM-4	NIST SP 800-150; STIX/TAX II
P54	Preparación frente a ataques asistidos por IA	Tendencias emergentes	PROTECT / DETECT	Art. 14 (Riesgos emergentes)	Art. 21.3 (Consideración de amenazas emergentes)	Futura métrica AI-sec (FY2026-27 estimado)	NIST AI RMF 1.0 (2023)
P55	Participación en ISACs / grupos de intercambio	Tendencias emergentes / ISCM	DETECT / RESPOND	Art. 25 (Coordinación de incidentes)	Art. 29 NIS2 (Redes CSIRT; grupos cooperación)	Métrica ISCM-1 (información compartida)	NIST SP 800-150; CISA JCDC
P56-P58	Preguntas abiertas	Transversal	Transversal	N/A (datos cualitativos)	N/A	N/A	N/A

P59	Autoevaluación cultura de ciberseguridad	Métricas y madurez	Transversal	Art. 15-16 (Profesionalidad y formación)	Art. 20-21 (Cultura de seguridad)	Indicador complementario cultural	NIST NICE Framework; NIST CSF 2.0: GV.OC
P60	Recomendación del instrumento	Calidad del instrumento	N/A	N/A	N/A	N/A	N/A

Tabla 2 — Cobertura de Indicadores FISMA FY2025 por Pregunta

Indicador FISMA FY2025	Dominio	Función	Preguntas de la encuesta que lo abordan
Gov-1: Cybersecurity Governance Program	Cybersecurity Governance	GOVERN	P1, P2, P4, P5
Gov-2: Leadership Accountability	Cybersecurity Governance	GOVERN	P2, P5, P30
Gov-3: Risk Tolerance (Suplementaria)	Cybersecurity Governance	GOVERN	P3, P4
SCRM-1: C-SCRM Plan and Policy	C-SCRM	GOVERN	P6, P7
SCRM-2: Supplier Risk Identification	C-SCRM	GOVERN	P6, P8, P9
SCRM-3: Supplier Risk Response	C-SCRM	GOVERN	P8, P9, P10
RA-1: Asset Inventory	Risk and Asset Management	IDENTIFY	P11, P14
RA-2: System Categorization	Risk and Asset Management	IDENTIFY	P12
RA-3: Risk Assessment	Risk and Asset Management	IDENTIFY	P13
CM-1: Configuration Baselines	Configuration Management	PROTECT	P15, P18
CM-2: Patch Management	Configuration Management	PROTECT	P16
CM-3: Vulnerability Scanning	Configuration Management	PROTECT	P17
IDAM-1: MFA Implementation	Identity and Access Management	PROTECT	P19
IDAM-2: Least Privilege / Access Reviews	Identity and Access Management	PROTECT	P20, P21
IDAM-3: Privileged Account Management	Identity and Access Management	PROTECT	P22
ZTA-1: Data Management Capabilities (Suplementaria)	Zero Trust / Data	PROTECT	P23, P24, P25
ZTA-2: Asset Integrity Monitoring (Suplementaria)	Zero Trust / ISCM	PROTECT / DETECT	P23, P32, P34

DP-1: Data Classification and Inventory	Data Protection and Privacy	PROTECT	P24
DP-2: Encryption	Data Protection and Privacy	PROTECT	P25
ST-1: Security Awareness Training	Security Training	PROTECT	P28, P29, P30
ST-2: Role-Based Training	Security Training	PROTECT	P28, P30
ISCM-1: Continuous Monitoring Program	ISCM	DETECT	P31, P33, P34, P53
ISCM-2: EDR Coverage	ISCM	DETECT	P32
ISCM-3: Event Logging (M-21-31)	ISCM	DETECT	P33
IR-1: Incident Response Plan	Incident Response	RESPOND	P36, P39, P40
IR-2: IR Testing	Incident Response	RESPOND	P37
IR-3: IR Metrics and SLAs	Incident Response	RESPOND	P38
CP-1: Contingency Plan	Contingency Planning	RECOVER	P41, P43
CP-2: Contingency Plan Testing	Contingency Planning	RECOVER	P42, P44

Tabla 3 — Cobertura Normativa ENS por Artículo del RD 311/2022

Artículo RD 311/2022	Contenido	Preguntas que lo abordan
Art. 5	Principio de gestión basada en riesgos	P3, P13
Art. 10	Principio de vigilancia continua	P31, P32, P33, P34, P35
Art. 13	Política de seguridad	P1, P2, P5
Art. 14	Gestión de riesgos	P3, P13, P27, P54
Art. 15	Profesionalidad	P28, P59
Art. 16	Formación	P28, P29, P30
Art. 19	Adquisición de productos y servicios	P6, P7, P8, P9
Art. 24	Vigilancia continua	P31, P34, P35
Art. 25	Respuesta a incidentes	P36, P37, P38, P39, P40
Art. 26	Continuidad de actividad	P10, P41, P42, P43, P44
Art. 34-36	Auditoría e informes	P47, P48
Arts. 37-40	Certificación	P45
Medida op.exp.1	Inventario de activos	P11, P14
Medida op.exp.3	Protección frente a código malicioso	P17, P32
Medida op.exp.4	Gestión de parches	P16
Medida op.exp.5	Gestión de cambios	P18
Medida op.exp.10	Registro de actividad	P33
Medida mp.acc.2	Acceso mínimo necesario	P21
Medida mp.acc.3	Control de acceso privilegiado	P22
Medida mp.acc.4	Proceso de control de acceso	P20
Medida mp.acc.5	Autenticación fuerte (MFA)	P19
Medida mp.com.2	Cifrado de comunicaciones	P25
Medida mp.eq.3	Seguridad en equipos	P15, P32
Medida mp.info.3	Clasificación de la información	P24
Medida mp.info.9	Copias de seguridad	P44

Tabla 4 — Cobertura NIS2 (Directiva UE 2022/2555) por Artículo

Artículo NIS2	Contenido	Preguntas que lo abordan
Art. 20	Gobernanza: responsabilidad de órganos de dirección	P2, P5, P30
Art. 21.1	Medidas de gestión de riesgos (proporcionalidad)	P3, P4, P12, P49, P51
Art. 21.2.a	Políticas de análisis de riesgos y seguridad de los SI	P3, P13, P24
Art. 21.2.b	Gestión de incidentes (detección y controles)	P17, P31, P32, P33
Art. 21.2.c	Continuidad operativa (BCP, DR, copias seguridad)	P10, P41, P42, P43, P44
Art. 21.2.d	Seguridad de la cadena de suministro	P6, P7, P8, P9
Art. 21.2.e	Seguridad en la adquisición, desarrollo y mantenimiento	P16, P18
Art. 21.2.f	Políticas y procedimientos para IR y evaluación de eficacia	P36, P37, P38
Art. 21.2.g	Prácticas básicas de ciberhigiene y formación	P15, P16, P17, P28, P29
Art. 21.2.h	Políticas y procedimientos de criptografía y cifrado	P25, P27
Art. 21.2.i	Seguridad de RRHH, IAM, acceso a activos	P19, P20, P21, P22
Art. 21.2.j	Uso de autenticación multifactor	P19
Art. 21.3	Amenazas emergentes y vulnerabilidades nuevas	P27, P54
Art. 23	Notificación de incidentes (24h/72h/1mes)	P39
Art. 24	Certificaciones y normas técnicas reconocidas	P45
Art. 26.3	Intercambio de información sobre amenazas	P53, P55
Art. 29	Redes CSIRT y grupos de cooperación	P40, P55

Kit de Encuesta FISMA 2025 — Mapeo Normativo · Versión 1.0 · Abril 2026

Fuentes: OMB M-25-04, FY2025 IG FISMA Reporting Metrics v2.0, NIST CSF 2.0, NIST SP 800-53 Rev.5, RD 311/2022, Directiva UE 2022/2555 (NIS2), ENISA Technical Guidance NIS2 (junio 2025)